Grupo Bimbo, S.A.B. de C.V. | ESG Scores Raw Data

BMV:BIMBO A (MI KEY: 4276592; SPCIQ KEY: 877906; TCUID: 53231)

Public

Year: Methodology Year: 2025
Question: Risk Governance
Include Modeled Scores : Yes

Risk Governance

Question

Does the company have governance mechanisms in place to oversee risks?

Rationale

This question assesses the effectiveness of a company's risk governance framework. For this, it is important the company's senior management and board of directors are not just aware of risks but also actively involved in managing them. While the board of directors is ultimately responsible for risk management, it is up to senior management to take the board's strategic direction and turn it into appropriate policies and procedures, and to effectively implement, execute, and monitor these policies.

The three lines of defense model is a recognized governance framework for managing risks. It lays out clear risk management responsibilities and accountabilities to ensure a company´s risk-related objectives are achieved. In this model, the first and second lines are responsible for executing and monitoring risk management activities. The third line operates independently to check how well the risk management processes are working.

Performance Summary	
Question Level Company Performance	25
Question Weight	43
Year-on-Year Change	0
Industry Average Score	50
Industry Highest Score	100

The question layout and the company's verified information is provided below. No information is shown if the company did not provide any information or if it opted out of sharing non-public information.

Additional Question Guidance & Information Display

Key Definitions

Board level responsibility: A dedicated role or committee at the level of the highest governing body consisting of only independent and/or non-executive board member(s). This could be a risk committee or an audit committee tasked with explicit responsibility for risk management overview. For two-tier boards, the board-level committee must be formed of members of the supervisory board.

Operational Management Functions (Three Lines of Defense Model)

Operational risk Ownership (first line): The employees or teams directly involved in producing and/or delivering products and services to clients. They are responsible for owning and managing risks in day-to-day operations. The first line is responsible for the execution of controls set by the second line. We expect clear assignment of risk management responsibilities at the business unit level, which could include roles such as risk owners, risk managers and business unit heads.

Risk management and compliance oversight (second line): The individual(s), committee(s) or body(ies) in the organization charged with monitoring and supporting risk management processes, ensuring risk management objectives are achieved. This oversight typically falls to senior management or the executive level, which are responsible for setting control standards and overseeing compliance. The second line responsibility may be split into several sub functions - related to risk type for example - from a main/group function in charge of monitoring risk. However, we expect that specific sub functions would report into an overarching role or main function as defined by the company. For two-tier boards, risk management responsibility as the second line of defense can be at the management board level. Examples of responsible people or committees include the chief risk officer, risk management committee and chief compliance officer. Given that the CEO has ultimate responsibility for all aspects of a company's operations, the CEO is not accepted here; rather, the expected function would report to senior management or the CEO.

Independent audit unit (third line): The unit tasked with advising and auditing to ensure policies are followed and processes are executed in line with management's selected performance goals and risk tolerances. This could be an internal audit team or a comparable external function, providing independent assurance that organizational practices are aligned with the company's risk strategy and policies, as implemented by the first and second lines. The independence of this unit ensures objective monitoring and control of various risks, safeguarding the organization's interests without conflicts of interest arising from other business priorities. This function typically reports directly to the board of directors on top of senior/executive management and remains separate from the implementation of processes or risk management to preserve its objectivity.

Note: The responsibilities of internal audit as part of the third line of defense extend beyond financial reporting compliance audits.

Data Requirements

To answer this question, it's important to focus on the organization's general risk management governance framework, rather than responsibilities defined in specific sections of the report such as Occupational Health & Safety, Human Rights or Climate Change.

Disclosure Requirements

The document(s) you have attached will be used to verify your response. Any response that cannot be verified in the attached document(s) will not be accepted.

Listed and/or publicly owned companies are required to provide links to public reports or corporate websites.

Non-listed companies are required to provide the following evidence, depending on the type of company:

- **Family-owned companies and privately owned companies** are required to provide public reports, corporate websites, or internal documents.
- **Cooperatives** are required to provide public reports, corporate websites, or internal documents.
- **State-owned companies** are required to report on their corporate governance in the public domain as their key stakeholder is the general public.

Please note: Answers in the form of "Confidential additional comments" for any type of non-listed company will not be accepted.

References

COSO Framework

The Institute of Internal Auditors

Standards & Frameworks

CSRD - GOV-1 Governance Bodies Role, GOV-2 Board Sustainability Oversight

Data View

QUESTION LEVEL INPUT	COMPANY ANSWER
Company has risk governance framework consisting of board level risk oversight and operational management functions (Three lines of defense model).	Applicable
Company has a risk governance framework with dedicated role or committee at board level for risk oversight	-
First line: company has a risk governance framework with operational risk management ownership with front-line employees or dedicated operational roles (e.g., Risk Managers, Business Unit Heads) who owns and manages risks	-
Second line: company has a risk governance framework with operational risk management ownership at the senior management or executive level responsible for setting control standards and oversees compliance with them	YES
Third line: company has a risk governance framework with operational risk management ownership with an internal audit function that provides independent assurance on the effectiveness of risk management	-

Questionnaire

Does the company have a risk governance framework in place?

Listed companies are required to provide links to public reports or corporate websites.

Non-listed companies are required to provide internal documents and/or links to public reports or corporate websites.

1. ◉

   Yes, the company has a risk governance framework.

   The company has a risk governance framework with **board level risk oversight**:

Grupo Bimbo, S.A.B. de C.V. | ESG Scores Raw Data

1. ☐ Dedicated role or committee at board level for risk oversight (independent and/or non-executive board member(s))

The company has a risk governance framework with dedicated **operational risk management functions** in place:

1. ☐ Operational Risk Ownership (first line): Front-line employees or dedicated operational roles (e.g., risk managers, business unit heads) own and manage risks.
2. ☑ Risk Management and Compliance Oversight (second line): A dedicated role(s) or committee(s) exist(s) at the senior management or executive level, which is responsible for setting control standards and oversees compliance with them (does not include the CEO).
3. ☐ Independent Audit Unit (third line): An internal audit function that provides independent assurance on the effectiveness of risk management and compliance processes.

2. ○ No, the company does not publicly report on its risk governance framework.
3. ○ Not applicable. Please provide explanations in the comment box below.
4. ○ Not known

Confidential additional comments

Use the text field below only in the following cases: (i) to describe significant changes in data or calculation methodology compared to last year's submission, (ii) to explain why a question is not applicable to your company's business model, (iii) to explain if your data deviates from the unit or format requested, or (iv) to provide supporting notes on translations of non-English references.